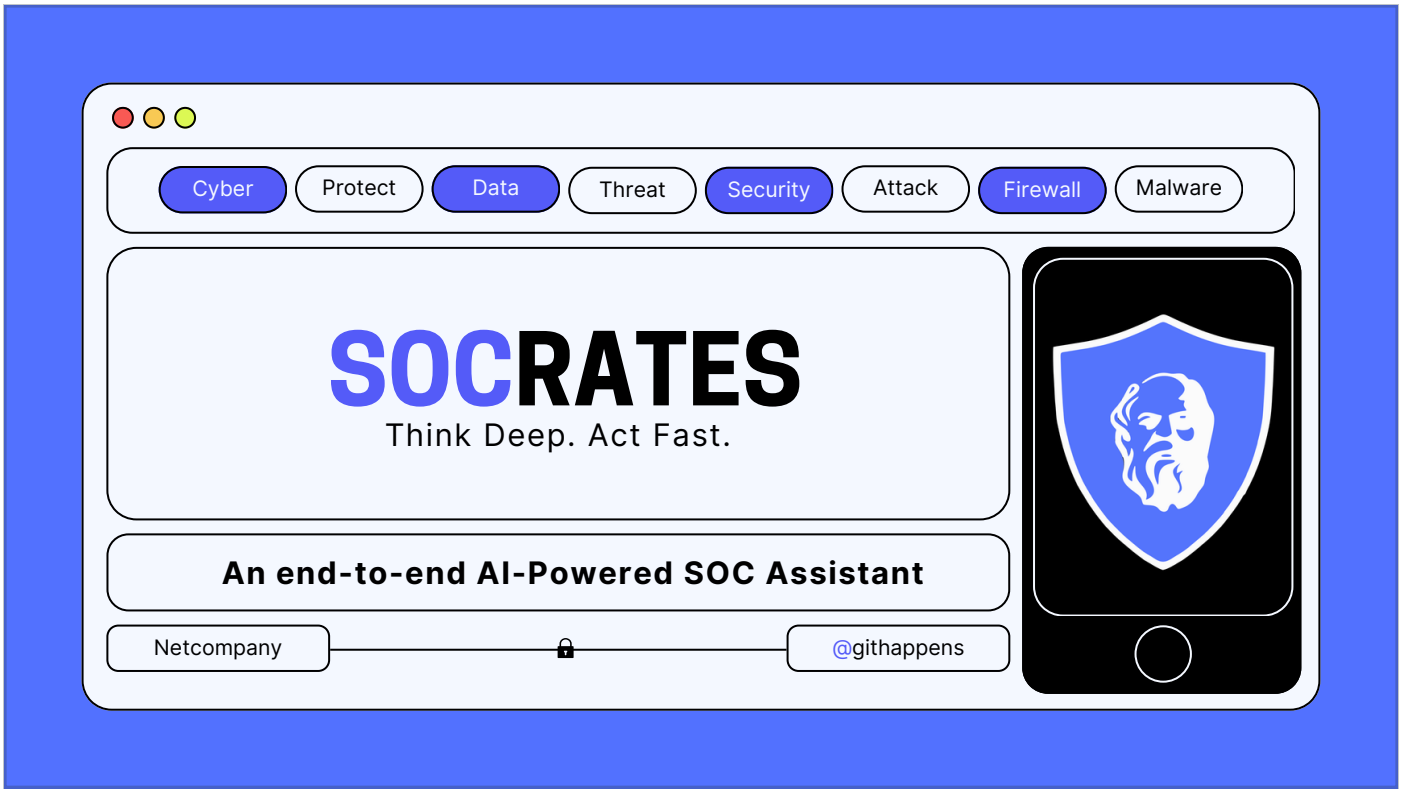


Καλησπέρα σε όλους, είμαι ο Βασίλης και μαζί με τον Σάββα είμαστε η ομάδα git happens.

Μαζί, δημιουργήσαμε το SOCrates: ένα σύστημα που αυτοματοποιεί την καθημερινότητα ενός SOC expert, διατηρώντας τον παράλληλα στο επίκεντρο της λήψης αποφάσεων.

Στόχος μας είναι η βέλτιστη αξιολόγηση των ειδοποιήσεων ασφαλείας και η αμεσότερη δυνατή ανταπόκριση σε κάθε απειλή.

THE CHALLENGE

- Security teams are overwhelmed by log volume
- Alert fatigue and delayed response
- Hard to bridge monitoring to real remediation

Σήμερα, οι συσκευές ασφαλείας παράγουν έναν τεράστιο όγκο δεδομένων.

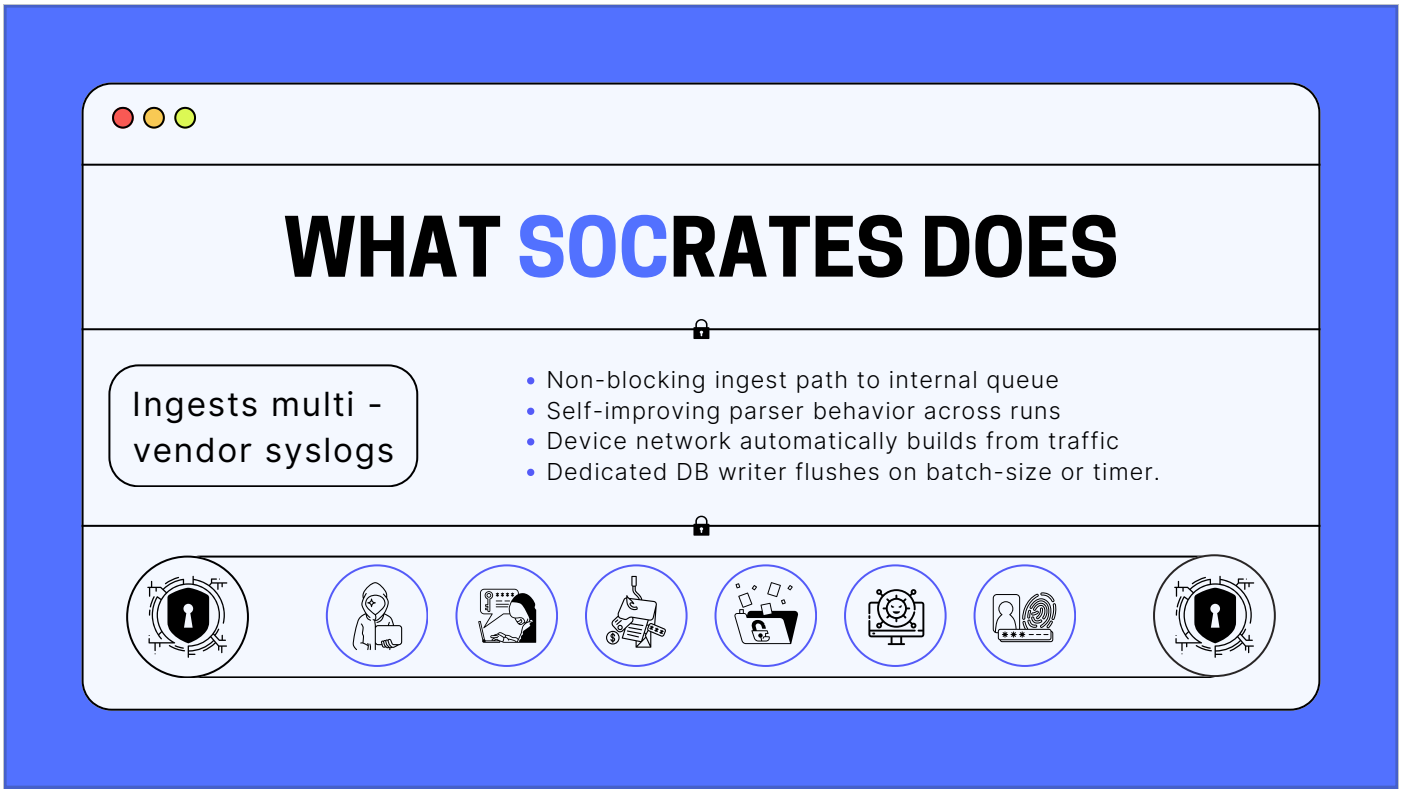
Οι αναλυτές καλούνται να ψάξουν χειροκίνητα μέσα σε ακατέργαστα logs για να βρουν την πραγματική απειλή, και μετά να μεταφράσουν αυτό το εύρημα σε άμεση δράση. Το αποτέλεσμα; Χάνεται πολύτιμος χρόνος κατά τη διάρκεια μιας επίθεσης.

Το SOCrates δημιουργήθηκε για να γεφυρώσει αυτό το χάσμα.

Το SOCrates συγκεντρώνει αμέτρητα logs από διαφορετικές πηγές —όπως συστήματα της Cisco, της Fortinet και της Palo Alto— και να τα "μεταφράζει" αυτόματα σε μια κοινή, κατανοητή μορφή.

Ταυτόχρονα από ένα κεντρικό dashboard, προσφέρει στους αναλυτές άμεση εικόνα των alerts και του τι συμβαίνει στο δίκτυο, ενώ με τη βοήθεια της τεχνητής νοημοσύνης αναλύει τα περιστατικά και προτείνει λύσεις.

Με λίγα λόγια, βγάζει το χάος από τη διαχείριση των logs, γλιτώνει πολύτιμο χρόνο και βοηθάει στην αντιμετώπιση των απειλών γρήγορα και στοχευμένα.



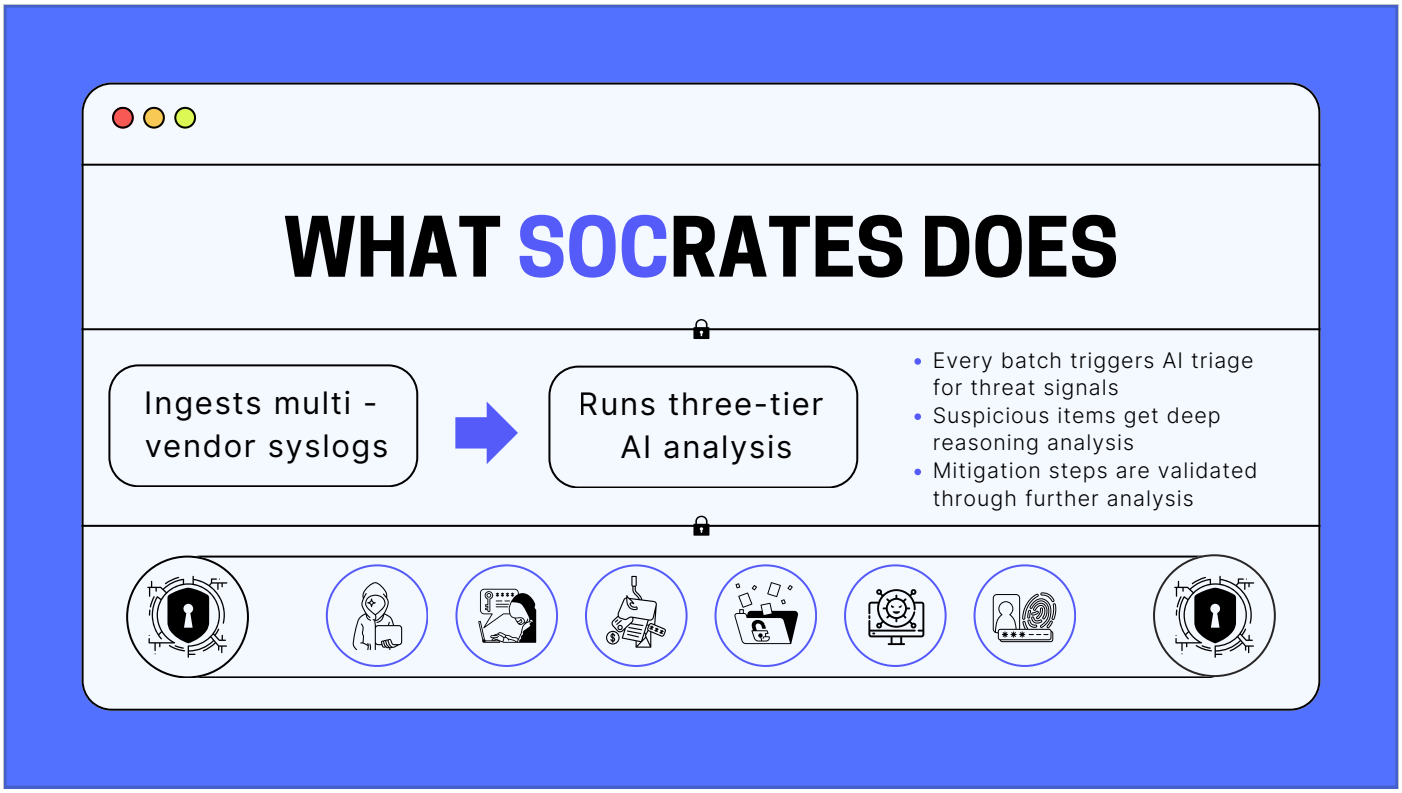
Οπότε, πώς ακριβώς λειτουργεί; Το backend λαμβάνει UDP logs από πραγματικές συσκευές, μέσω ενός non-blocking ingest path.

Με αυτόν τον τρόπο εξασφαλίζουμε ότι κάθε πακέτο που φτάνει στο σύστημά μας, μπαίνει στην εσωτερική ουρά για επεξεργασία.

Στη συνέχεια, τα δεδομένα περνούν από τον custom parser που αναπτύξαμε. Εκεί, φιλτράρονται ώστε να κρατήσουμε μόνο την ουσιαστική πληροφορία, εξοικονομώντας έτσι πολύτιμα tokens για τη μετέπειτα ανάλυση.

Αυτό γίνεται είτε βάσει γνωστών προτύπων, είτε δυναμικά: δηλαδή αν λάβουμε ένα log από μία πρωτοεμφανιζόμενη συσκευή, το LLM δημιουργεί αυτόματα ένα νέο regex, το οποίο αποθηκεύεται και επαναχρησιμοποιείται.

Ταυτόχρονα, οι συσκευές του δικτύου καταγράφονται αυτόματα στην SQLite βάση μας και παραστούνται σχηματικά ,για γραφική περιήγηση στο frontend. Από την άλλη, τα logs αποθηκεύονται μαζικά, είτε ανά 100 εγγραφές είτε κάθε 2 λεπτά. Η SQLite βάση λειτουργεί αποδοτικά για το demo μας -ειδικά αφού κάνουμε εκτεταμένη χρήση indexes- ωστόσο, σε ένα deployment μεγαλύτερης κλίμακας, θα επιλέγαμε κάτι πιο robust.

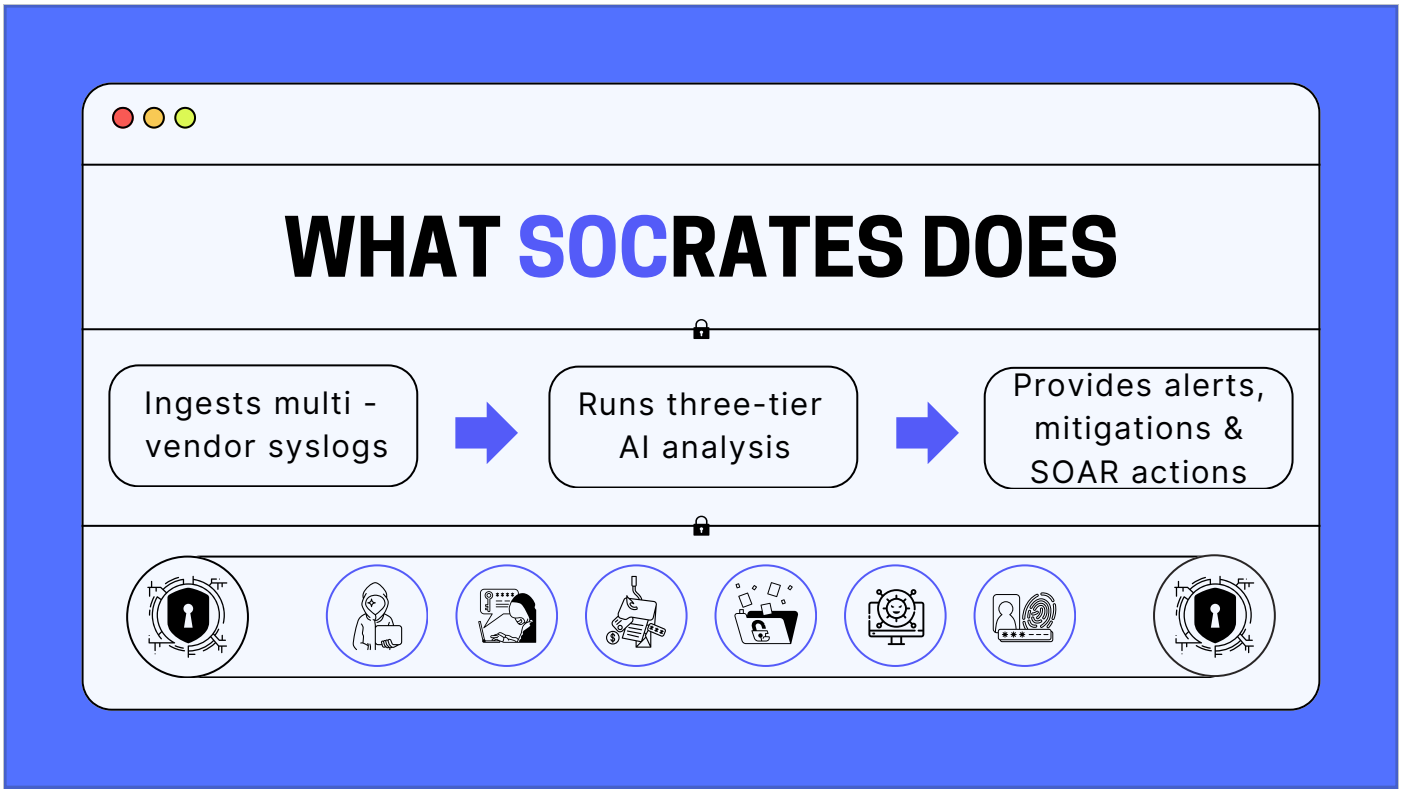


Με κάθε batch εγγραφών λοιπόν, τα logs αποστέλλονται στο απλούστερο AI μοντέλο για να αξιολογηθούν ως προς την πιθανότητα κινδύνων και ανωμαλιών.

Τα ύποπτα στοιχεία, μαζί με τις πρόσφατες ειδοποιήσεις και το γενικότερο context του δικτύου, περνούν στη συνέχεια από μια εις βάθος ανάλυση (deep reasoning).

Τέλος, δημιουργήσαμε ένα τρίτο επίπεδο αξιολόγησης το οποίο, μετά από μια ενέργεια SOAR (όπως το μπλοκάρισμα μιας θύρας), λαμβάνει τα νεότερα ενεργά logs και τα αναλύει για να επαληθεύσει εάν η επίθεση σταμάτησε πραγματικά.

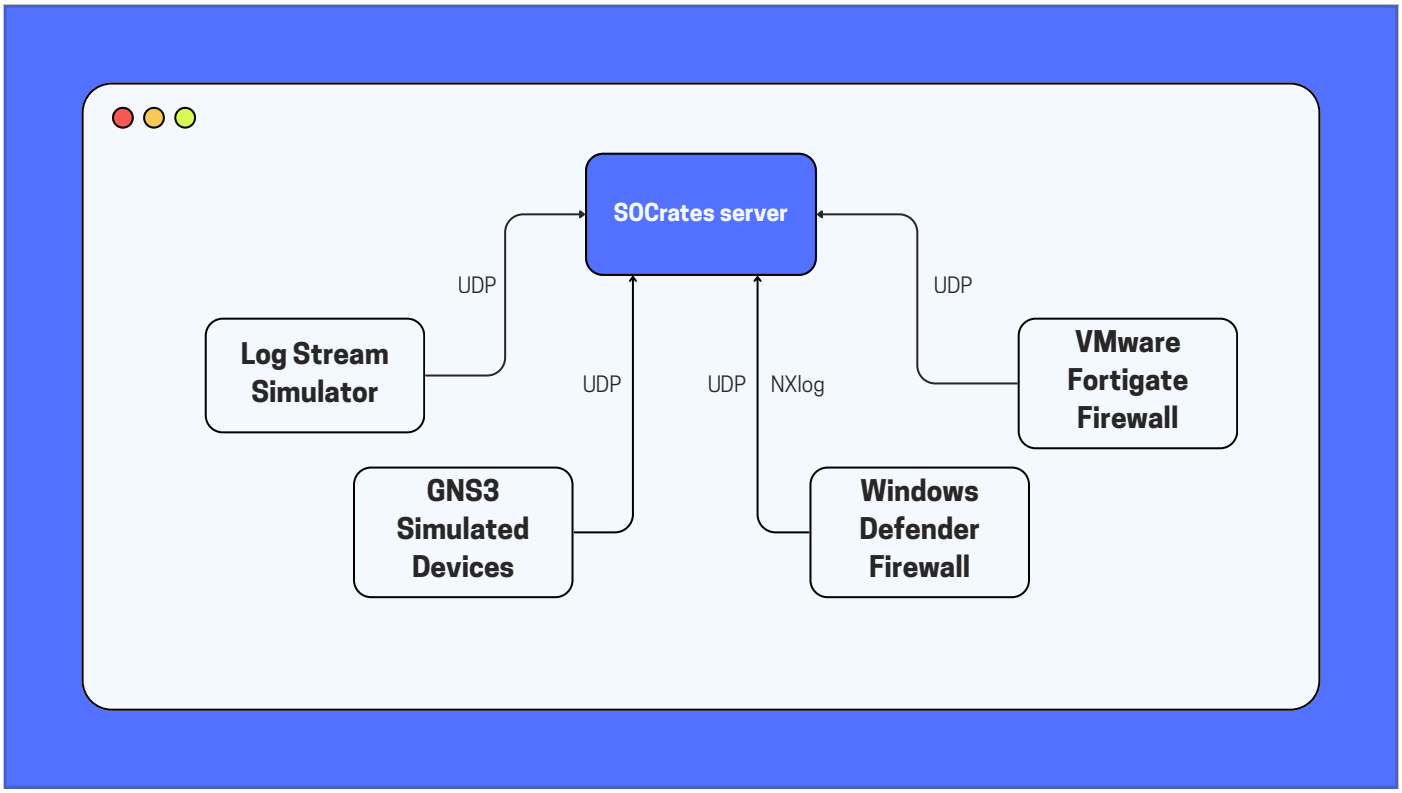
Αυτή η μεθοδολογία μάς επιτρέπει να έχουμε: Μια ευρεία, οικονομική σε tokens σάρωση, μία εστιασμένη ανάλυση, που παράγει στοχευμένα mitigation steps, αλλά και παρακολούθηση ολόκληρου του κύκλου ζωής ενός περιστατικού, έτσι ώστε να επιβεβαιώσουμε ότι η απειλή εξουδετερώθηκε.



Τελικά, το socrates δημιουργεί ξεκάθαρες ειδοποιήσεις ανά συσκευή -οι οποίες αποθηκεύονται στην βάση- για τυχόν κινδύνους, καθώς και προτάσεις για την αντιμετώπιση τους.

Φυσικά, προσφέρουμε και τη δυνατότητα προαιρετικής, αυτόματης απόκρισης με ενέργειες αποκλεισμού μέσω API playbooks.

Όλα αυτά, πλαισιώνονται από αναλυτικά στατιστικά, το audit trail και το πλήρες ιστορικό των ειδοποιήσεων.



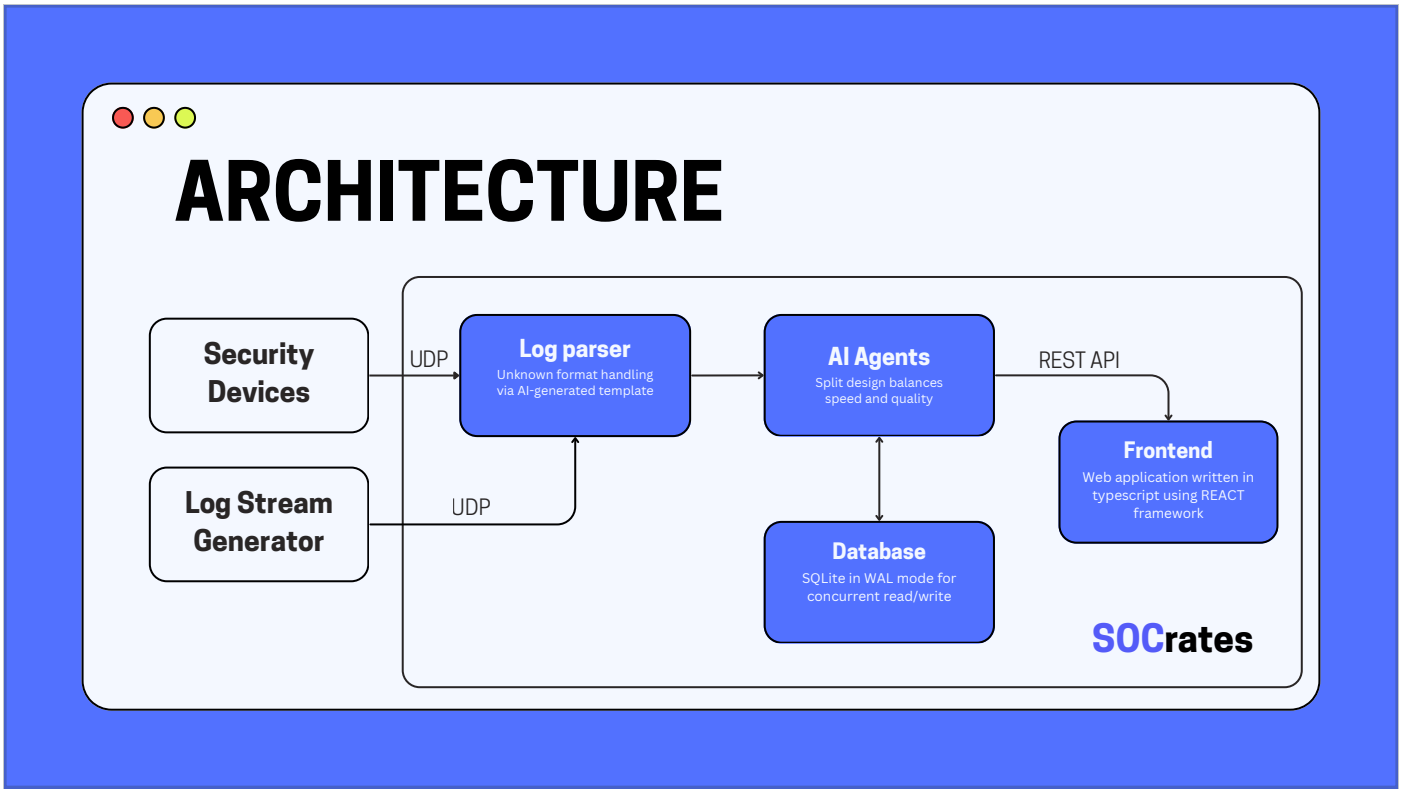
Για να τεστάρουμε αυτή τη ροή, χρειαστήκαμε ρεαλιστικά δεδομένα τα οποία πήραμε απο δίαφορες πηγές.

Αρχικά, φτιάξαμε έναν δικό μας συνθετικό log simulator που προσομοιώνει κίνηση σε firewall βάσει πραγματικών datasets.

Επιπλέον εργαλεία όπως το GNS3 και VMware για την προσομοίωση πραγματικών συσκευών.

Τέλος, χρησιμοποίσαμε το προ-εγκατεστημένο windows firewall, προσομοιώντας logs με εργαλεία όπως το EICAR.

Μέσα από αυτό το stress-test εντοπίσαμε και λύσαμε πρακτικά ζητήματα, όπως το alert fatigue, εφαρμόζοντας μηχανισμούς που αποτρέπουν τον καταιγισμό του χρήστη με επαναλαμβανόμενες ειδοποιήσεις.

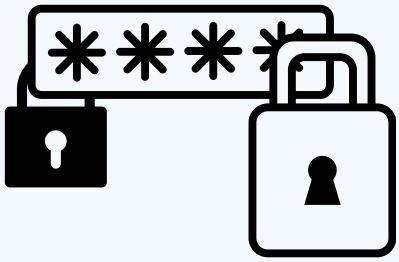


Κάνοντας, λοιπόν, ένα zoom out στην αρχιτεκτονική του project, παρατηρούμε την εξής ροή:

Τα raw logs ρέουν ασταμάτητα στο σύστημα και επεξεργάζονται από τους AI agents, ενώ το Frontend αναλαμβάνει να αντλήσει όλα τα live δεδομένα δυναμικά, κάνοντας polling στα κατάλληλα REST API.

THE KEY TO OUR AGENTIC WORKFLOW

- Infinite Context by using Retrieval-Augmented Generation (RAG)
- Guaranteed Structured Outputs
- Native Tool Calling
- Autonomous Evaluation



Αντίθετα με την προηγούμενη διαφάνεια, σε αυτή θα κάνουμε ένα zoom in στο λεγόμενο Agentic Workflow, το οποίο βρίσκεται στην καρδία του συγκεκριμένου project.

Αρχικά, κανένα LLM δεν γνωρίζει εξ ορισμού το δίκτυό μας. Γι' αυτό ενσωματώσαμε αρχιτεκτονική RAG (Retrieval-Augmented Generation). Αυτό δίνει στον agent μας "άπειρο context", καθώς μπορεί να ανατρέχει άμεσα στο ιστορικό των logs, τις αναλύσεις και στα δεδομένα συσκευών του δικού μας περιβάλλοντος πριν πάρει αποφάσεις.

Έπειτα, για να είμαστε σίγουροι για την συνοχή των πρώτων δύο επιπέδων ανάλυσης, περάσαμε από την κλασική έξοδο κειμένου στο να χρησιμοποιούμε αυστηρά Pydantic models (Structured Outputs). Με αυτόν αναγκάζουμε το LLM να μας επιστρέφει δομημένα δεδομένα. Το αποτέλεσμα; Μηδενίσαμε πλήρως τα λεγόμενα "JSON hallucinations" και τα σφάλματα στην ανάλυση των logs.

Στη συνέχεια, αξιοποιήσαμε το Native Tool Calling (του OpenAI). Το οποίο σημαίνει ότι αντί να δίνουμε απλώς λεκτικές οδηγίες στο μοντέλο, ορίσαμε συγκεκριμένες ενέργειες απόκρισης ως JSON Schema tools. Έτσι, ο agent μας πλέον αποφασίζει αυτόνομα το πότε και ποιο εργαλείο πρέπει να καλέσει για να λύσει το πρόβλημα.

Τέλος, κλείνουμε τον κύκλο με Autonomous Evaluation, όπου το σύστημα αξιολογεί μόνο του τα βήματα και τα συμπεράσματά του, διασφαλίζοντας τη μέγιστη δυνατή ακρίβεια.

WINDOWS SERVER SOAR ACTIONS

TESTED ON A LOCAL MACHINE AND PERFORMING AUTONOMOUS ACTIONS SUCH AS:

- **OPENING/CLOSING** A SPECIFIC **PORT** FOR EIHER **UDP**, **TCP** OR BOTH FOR PROTOCOLS IN WINDOWS FIREWALL
- **BLOCKING/UN-BLOCKING** A SPECIFIC **IP** IN WINDOWS FIREWALL
- **KILLING** SPECIFIC **PROCESSES** THAT MAY RUN ON THE WINDOWS SERVER AND BE DEMEED **DANGEROUS** BY THE **AI**
- **QUARANTINE** A SPECIFIC **FILE** IN THE WINDOWS SERVER, **DISABLING** ALL **ACCESS** TO IT

FORTIGATE FIREWALL SOAR ACTIONS

TESTED USING THE PROVIDED VM USING VMWAREAND PERFORMING AUTONOMOUS ACTIONS SUCH AS:

- **OPENING/CLOSING** A SPECIFIC **PORT** FOR EIHER **UDP**, **TCP** OR BOTH FOR PROTOCOLS IN WINDOWS FIREWALL
- **BLOCKING/UN-BLOCKING** A SPECIFIC **IP** IN WINDOWS FIREWALL

Το πιο δυνατό μας σημείο είναι η δυνατότητα συνομιλίας με την Τεχνητή Νοημοσύνη για την εκάστοτε κατάσταση του δικτύου.

Ο χρήστης συνομιλεί σε φυσική γλώσσα, και αν του πεις, για παράδειγμα, "μπλόκαρε αυτή την IP", θα καταλάβει την πρόθεση, θα σου ζητήσει follow-up διευκρινίσεις αν χρειαστεί, και θα εκτελέσει την ενέργεια.

Η συγκεκριμένη ενέργεια εφαρμοστήκε για firewalls τύπου fortigate και windows server, με την δυνατότητα να εφαρμοστεί αργότερα με ευκολία και για άλλους τύπους συσκευών μέσω της modular αρχιτεκτονικής μας.

Περαιτέρω συσκευές, θα συνεχίσουν να αναλύονται κανονικά μέσω του AI augmented parser μας.

Ήρθε η ώρα, όμως, να τα δούμε όλα αυτά και στην πράξη…

Το περιβάλλον του χρήστη έχει σχεδιαστεί για πραγματικές ροές εργασίας (workflows) ενός SOC, και όχι απλώς για να δείχνει όμορφα γραφήματα. Μπορούμε να διερευνήσουμε μια ειδοποίηση, να τη συσχετίσουμε άμεσα με τα logs που την προκάλεσαν, και να εκτελέσουμε μια ενέργεια αποκλεισμού — όλα μέσα από το ίδιο περιβάλλον.

Το SOCrates αποδεικνύεται ως ένα ολοκληρωμένο σύστημα, κλείνοντας πλήρως τον κύκλο ανίχνευσης και απόκρισης.

Ευχαριστούμε